

File Inclusion

A **File Inclusion vulnerability** occurs when a web application allows a user to control which file is "included" or executed by the server-side script. Developers often use functions like `include()`, `require()`, or `render()` to load common pieces of code (like a header or a language file). If the application doesn't sanitize the input, an attacker can manipulate the path to point elsewhere.

There are two distinct types:

- **Local File Inclusion (LFI)**: The attacker tricks the server into opening files already stored on the local filesystem (e.g., `/etc/passwd` on Linux or `C:\Windows\win.ini` on Windows).
 - **Remote File Inclusion (RFI)**: The attacker tricks the server into fetching and executing a file hosted on a completely different, attacker-controlled server.
-

History & Evolution

Past (The "Wild West" of PHP)

In the early 2000s, PHP was notorious for File Inclusion. Two settings, `register_globals` and `allow_url_include`, were often **On** by default. This made RFI a "God-mode" exploit; you could literally point a URL parameter to your hosted shell, and the server would run it instantly.

Present (Modern Web & Hardened Configs)

Most modern servers have RFI disabled by default. However, **LFI** is still incredibly common. Attackers have moved from simple pathing to using **PHP Wrappers** (like `php://filter`) to bypass filters and read source code in Base64 format.

- **Current Tools:**
 - * **Burp Suite (Intruder)**: For fuzzing paths.
 - **FFUF / Gobuster**: For brute-forcing hidden files.
 - **LFIsuite**: An automated tool specifically for finding and exploiting LFI.

The Future (Cloud & Serverless)

As we move toward "Serverless" functions (AWS Lambda) and containers (Docker), File Inclusion is evolving. Attackers now use LFI to query **Cloud Metadata Services** (e.g., the

169.254.169.254 IP) to steal temporary cloud credentials and take over the entire infrastructure.

Working Procedure: The Mechanism

The core technique used in File Inclusion is **Path Traversal** (also known as the "Dot-Dot-Slash" attack).

- 1. **The Trigger:** A URL looks like this:
`https://site.com/view.php?page=contact.php.`
- 2. **The Manipulation:** The attacker changes it to `?page=../../../../etc/passwd.`
- 3. **The Server's Logic:** Each `../` tells the operating system to "go up one directory." Eventually, the path hits the root directory and then dives back down into the sensitive system files.

Comparison: LFI vs. Others

Feature	LFI / RFI	Directory Traversal	Remote Code Execution (RCE)
Goal	To include/execute a file.	To read a file.	To run commands on the OS.
Mechanism	Exploits <code>include()</code> functions.	Exploits file system access.	The final result of a successful RFI.
Impact	Very High (can lead to RCE).	Medium (Sensitive data leak).	Critical (Full takeover).

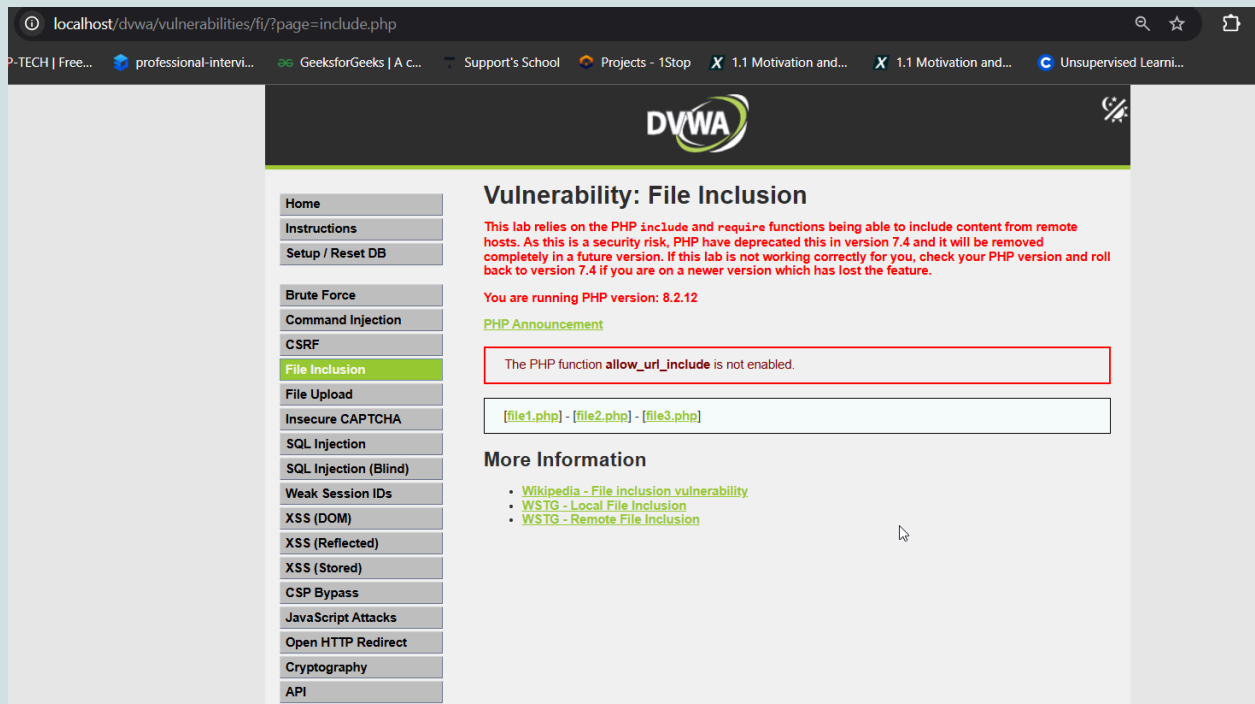
Example: The "Base64 Trick"

A common professional technique to bypass security filters that block the word `passwd` is using PHP filters to read the source code of the application itself.

Scenario: You want to see the database password in `config.php`.

1. **Payload:**
`?page=php://filter/convert.base64-encode/resource=config.php`
2. **Result:** Instead of executing `config.php`, the server returns the code as a **Base64 string**.
3. **The Win:** You decode that string on your terminal and read the raw PHP code, including secret API keys and database credentials.

DVWA lab low-level example:



The screenshot shows the DVWA web application interface in a browser. The URL bar indicates the page is `localhost/dvwa/vulnerabilities/fi/?page=include.php`. The left sidebar contains a menu of vulnerability categories, with "File Inclusion" selected. The main content area is titled "Vulnerability: File Inclusion" and includes a warning about the deprecation of the `allow_url_include` function in PHP 7.4. Below this, a red box states "The PHP function `allow_url_include` is not enabled." A text input field contains the payload `[file1.php] - [file2.php] - [file3.php]`. The "More Information" section provides links to Wikipedia, WSTG Local File Inclusion, and WSTG Remote File Inclusion.

localhost/dvwa/vulnerabilities/fi/?page=include.php

professional-intervi... GeeksforGeeks | A c... Support's School Projects - 1Stop 1.1 Motivation and... 1.1 Motivation and... Unsupervised Learni...

DVWA

Home
Instructions
Setup / Reset DB

Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript Attacks
Open HTTP Redirect
Cryptography
API

Vulnerability: File Inclusion

This lab relies on the PHP `include` and `require` functions being able to include content from remote hosts. As this is a security risk, PHP have deprecated this in version 7.4 and it will be removed completely in a future version. If this lab is not working correctly for you, check your PHP version and roll back to version 7.4 if you are on a newer version which has lost the feature.

You are running PHP version: 8.2.12

PHP Announcement

The PHP function `allow_url_include` is not enabled.

[file1.php] - [file2.php] - [file3.php]

More Information

- Wikipedia - File inclusion vulnerability
- WSTG - Local File Inclusion
- WSTG - Remote File Inclusion

localhost/dvwa/vulnerabilities/fi/?page=file1.php

TECH | Free... professional-intervi... GeeksforGeeks | A c... Support's School Projects - 1Stop X 1.1 Motivation and... X 1.1 Motivation and... C Unsupervised Learn...

DVWA

Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript Attacks
Open HTTP Redirect
Cryptography

Vulnerability: File Inclusion

File 1

Hello gordonb
Your IP address is: ::1
[\[back\]](#)

More Information

- [Wikipedia - File inclusion vulnerability](#)
- [WSTG - Local File Inclusion](#)
- [WSTG - Remote File Inclusion](#)

localhost/dvwa/vulnerabilities/fi/?page=file3.php

P-TECH | Free... professional-intervi... GeeksforGeeks | A c... Support's School Projects - 1Stop X 1.1 Motivation and... X 1.1 Motivation and... C Unsupervised Learn...

DVWA

Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript Attacks
Open HTTP Redirect
Cryptography

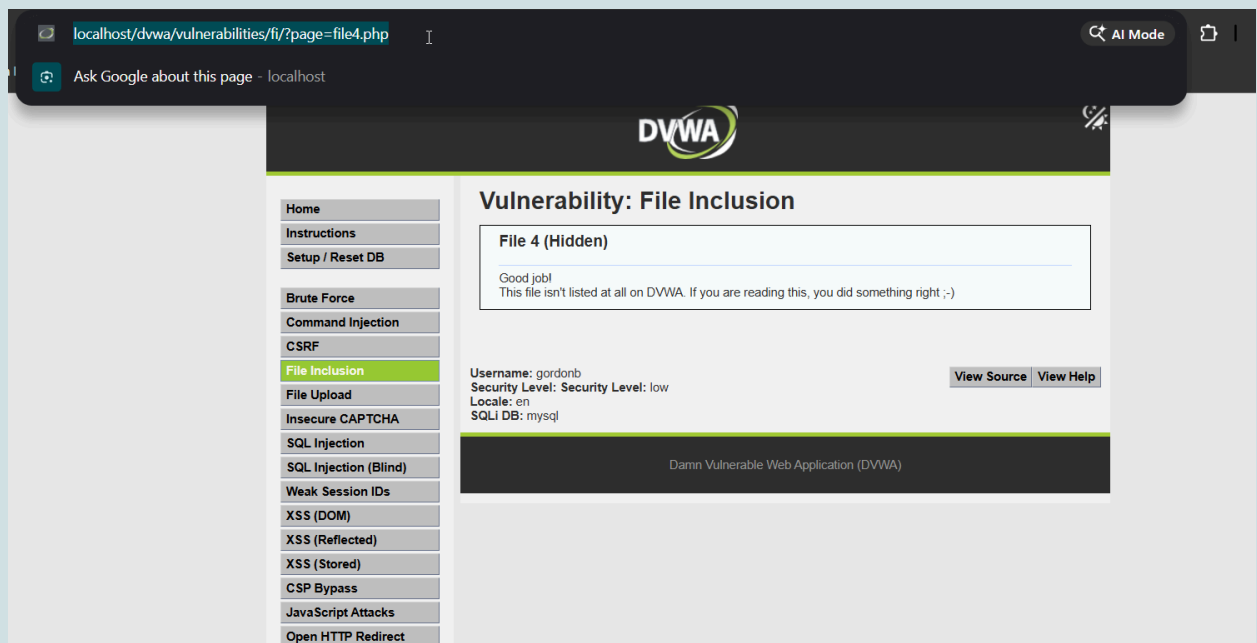
Vulnerability: File Inclusion

File 3

Welcome back gordonb
Your IP address is: ::1
Your user-agent address is: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36
You came from: http://localhost/dvwa/vulnerabilities/fi/?page=include.php
I'm hosted at: localhost
[\[back\]](#)

More Information

- [Wikipedia - File inclusion vulnerability](#)
- [WSTG - Local File Inclusion](#)
- [WSTG - Remote File Inclusion](#)



Causing Effects: The Impact

- **Remote Code Execution (RCE):** By including a file that contains code (like a log file you've "poisoned"), you gain a shell.
- **Information Disclosure:** Reading `/etc/passwd` to find valid usernames on the system.

- **Source Code Theft:** Stealing the backend logic to find more vulnerabilities.
 - **Denial of Service (DoS):** Pointing the inclusion to a large file like `/dev/urandom` to crash the server's memory.
-

Modern Trends: Log Poisoning

When you can't find a sensitive file to include, you **create** one. This is called **Log Poisoning**.

1. An attacker sends a request to the server with a "User-Agent" containing PHP code:
`<?php system($_GET['cmd']); ?>`.
 2. The server logs this request in `access.log`.
 3. The attacker uses LFI to include `access.log`.
 4. The server sees the PHP code in the log file and executes it. **Boom—you have RCE.**
-

Prevention (The Professional Fix)

1. **Avoid passing user input to file functions:** Use an ID system. (e.g., `?page=1` instead of `?page=contact.php`).
 2. **Whitelisting:** Only allow specific filenames to be included.
 3. **Disable Dangerous Settings:** In PHP, ensure `allow_url_include = Off`.
 4. **Chroot Jail:** Limit the web server's ability to "see" anything outside of its own folder.
-

Summary

File Inclusion is the art of manipulating file paths to trick a server into executing unintended code or revealing its secrets. While **RFI** is the "holy grail," **LFI** remains a critical threat, especially when chained with techniques like PHP filters or Log Poisoning to achieve full server takeover.